Feature 01 | Priority: HIGH

Authentication & Login

File: App.jsx Status: Mock Data

📌 Status Saat Ini

KONDISI FRONTEND

- Login menggunakan **hardcoded mock users** di `App.jsx` (superadmin / viewer).
- Password perbandingan **plaintext** di sisi client.
- Tidak ada JWT, session, atau API call.
- Role-based tab visibility sudah **implemented** (superadmin vs viewer).

🗄 Database — users

SCHEMA YANG DIBUTUHKAN

`id`	UUID	Primary key
`username`	String	Unique, untuk login
`password`	String	Hashed (bcrypt / argon2)
`name`	String	Nama tampilan
`role`	Enum	'superadmin' | 'viewer'
`role_label`	String	Label UI ('Super Administrator')
`is_active`	Boolean	Bisa dinonaktifkan tanpa hapus
`created_at`	DateTime	Auto-generated

🔌 REST API Endpoints

ENDPOINT YANG DIBUTUHKAN

POST	`/api/auth/login`	Terima { username, password }, return JWT + user info.
POST	`/api/auth/logout`	Invalidate refresh token (jika dipakai).

GET `/api/auth/me` Return user info berdasarkan JWT di header.

RESPONSE LOGIN BERHASIL

```
{ token, user: { id, username, name, role, roleLabel, allowedTabs } }
```

🔒 Security Requirements

CHECKLIST KEAMANAN

- Password **harus** di-hash server-side (bcrypt, cost ≥ 10).
- JWT access token: **short-lived** (15 menit), refresh token: 7 hari.
- RBAC enforcement **server-side** — jangan hanya andalkan frontend.
- Rate limit login endpoint (max 5 attempts / minute per IP).
- Jangan kirim `password` field dalam response.